

Hands-On-Learning: Enforcing Zero Trust: PDP vs. PEP on Windows

Learning Objectives

By the end of this activity, learners will be able to:

- Differentiate between **Policy Decision Point (PDP)** and **Policy Enforcement Point (PEP)**.
 - Apply software restriction policies to control application execution.
 - Test how **administrative roles vs. standard users** experience different levels of access.
-

Description

Learners will create two users: ZT_Admin and ZT_Guest.

They will set up a policy so that:

- ZT_Admin can open **Notepad.exe**.
- ZT_Guest is **blocked** from opening **Notepad.exe**.

This simulates **Zero Trust enforcement** where policy decisions (rules) are made centrally and enforced based on identity.

Structure of the Activity

Title: Blocking Notepad.exe for ZT_Guest

Tools Used: Windows Local Security Policy (secpol.msc), Local Users & Groups (compmgmt.msc)

Scenario

A Zero Trust architecture requires that **access is not assumed by default** — even basic apps may be restricted.

As the security administrator, you must allow only trusted users (ZT_Admin) to run a program (Notepad), while blocking untrusted users (ZT_Guest).

Objective

Demonstrate how PDP defines rules and PEP enforces them using Windows policies.



Instructions for Learners (Step-by-Step)

Step 1: Create Two Local Users

1 Press **Windows + R**, type compmgmt.msc, and press Enter.

2 Navigate to **Local Users and Groups → Users**.

3 Right-click **Users** → **New User**.

Username: ZT_Admin → set password (e.g., Lab@123).

Uncheck User must change password at next logon.

Check Password never expires.

Click **Create**.

4 Repeat the same for ZT_Guest.

5 Close the window.

Step 2: Assign Group Memberships

1 Double-click ZT_Admin.

Go to **Member Of** tab → click **Add** → type Administrators → OK.

2 Double-click ZT_Guest.

Ensure it is **only** a member of the Users group.

(This ensures SRP won't apply to ZT_Admin, but will apply to ZT_Guest.)

Step 3: Define Policy Decision (PDP)

Before enforcement, document the rules:

Rule 1: ZT_Admin → Allowed to run Notepad.

Rule 2: ZT_Guest → Denied from running Notepad.

This represents the **decision point**.

Step 4: Apply Policy Enforcement (PEP)

- 1 Press **Windows + R**, type `secpol.msc`, press Enter.
- 2 Expand **Security Settings** → **Software Restriction Policies**.
If none exist, right-click → **Create New Policies**.
- 3 Right-click **Additional Rules** → **New Path Rule**.
- 4 Enter the path:

- 5 C:\Windows\System32\notepad.exe
- 6 Set **Security Level: Disallowed** → Click **OK**.
- 7 On the left, click **Enforcement**.
 - Ensure it is set to **All users except local administrators**.
 - (This way, ZT_Admin won't be affected, but ZT_Guest will be blocked.)

Step 5: Test the Policy

1 Log out and log in as ZT_Admin.

Press **Windows + R**, type notepad, press Enter. Notepad should open normally.

2 Log out and log in as ZT_Guest.

Press **Windows + R**, type notepad, press Enter. You should see: “This program is blocked by group policy.”

Step 6: Optional Advanced Step (For Enterprise Users with AppLocker)

If learners have **Windows Enterprise/Education**, they can use **AppLocker** instead of SRP for per-user targeting:

Open **gpedit.msc** → **Computer Configuration** → **Windows Settings** → **Security Settings** → **Application Control Policies** → **AppLocker**.

Create a **New Executable Rule**.

Set rule to **Deny** → select **ZT_Guest**.

Choose program path: C:\Windows\System32\notepad.exe.

Save → Enforce rules.

Now AppLocker will **only block ZT_Guest**, regardless of group membership.

Organize Information for Peer Review

Title Page: "Blocking Notepad for ZT_Guest using Zero Trust Policies",
[Your Name], [Date]

Requirement 1: Create ZT_Admin and ZT_Guest.

Requirement 2: Apply SRP to block Notepad.exe.

Requirement 3: Test results under each user account.

Instructions for Documenting and Sharing the Project for Peer Review



1. Document the Project

Use word processing software to create your project summary and reflections.

Ensure all sections of the project document structure are completed.

Proofread and edit your report for clarity and accuracy.



2. Share the Project

Save your report and presentation in PDF format.

Upload your documents to the “Peer Review” area in the course shell.

Provide a brief description of your project in the submission post.



3. Peer Review

Review the projects submitted by your peers.

Provide constructive feedback and comments on their work.